

Phishing is one of the most common and effective forms of cyber attack, affecting both individuals and organisations across the UK. It involves attempts to trick users into revealing sensitive information such as passwords, financial details, or personal data. These attacks are typically disguised as legitimate communications, making them difficult to recognise without a clear understanding of how they operate.

At its core, phishing relies on deception rather than technical sophistication. Attackers often impersonate trusted sources such as banks, well-known companies, or colleagues within an organisation. By creating a sense of urgency or importance, they encourage users to act quickly without verifying the legitimacy of the message.

Phishing attacks can take several different forms, each designed to exploit different behaviours:

- Email phishing – fraudulent emails designed to appear legitimate
- Spear phishing – targeted attacks aimed at specific individuals or roles
- Smishing – phishing conducted through SMS or text messages
- Vishing – phone-based attacks attempting to extract sensitive information
- Clone phishing – imitation of genuine communications with malicious content

Although phishing attacks vary in format, they generally follow a similar process. An attacker creates a convincing message using familiar branding, tone, and formatting. The message typically includes a request, such as clicking a link, downloading an attachment, or providing information. If the user interacts with the content, they may be redirected to a fake website or unknowingly expose sensitive data. In some cases, malicious software may also be installed.

For individuals, phishing can result in unauthorised access to personal accounts, financial loss, identity theft, and exposure of private information. Because many accounts are interconnected, a single successful attack can lead to further compromise across multiple services. For businesses, the impact is often more significant, including data breaches, financial fraud, operational disruption, and reputational damage. Phishing is frequently used as an entry point for more advanced attacks, making it a critical concern for organisational security.

Phishing remains highly effective because it targets human behaviour rather than technical weaknesses. Attackers commonly rely on tactics such as urgency, impersonation, and realistic design elements to increase the likelihood of success.

Recognising phishing attempts is a key part of reducing risk. Common warning signs include:

- Unexpected messages requesting sensitive information
- Urgent or threatening language demanding immediate action
- Email addresses or phone numbers that do not match the claimed sender
- Links that lead to unfamiliar or misspelled websites
- Attachments that were not expected or seem unusual
- Generic greetings instead of personalised communication

While not all phishing attempts are obvious, these indicators can help identify suspicious activity.

Protecting against phishing involves a combination of awareness and practical measures:

- Verifying the source of messages before responding or clicking links
- Accessing websites directly rather than through email links
- Using multi-factor authentication to add an extra layer of security
- Keeping devices and software updated
- Reporting suspicious messages to relevant providers or IT teams
- Providing regular awareness training within organisations

For businesses, additional measures such as email filtering, security policies, and simulated phishing exercises can further reduce risk.

This page provides an overview of phishing, including how it works, how to recognise it, and how to reduce its impact. Developing awareness of these techniques is an essential step in improving both personal and organisational cyber security.